EPSS Study Rulebook

These four rules are fixed before anyone looks at results. Change one only if all four of you agree and you note why in the report.

1. Time window

- **Listed CVEs:** every CVE added to the CISA KEV catalog from 1 Jan 2024 to 31 Dec 2024 (the `dateAdded` field).
- **EPSS data:** day -60 to day +60 around each listing, so roughly 2 Nov 2023 to 1 Mar 2025.
- **One model version only:** this whole range should sit inside EPSS v3 (released March 2023; v4 arrived March 2025). Confirm both dates in the EPSS docs before locking.
- **Size check on Day 1:** KEV adds roughly 180-190 CVEs a year, so a full year gives about 150-190 listed CVEs. The "2-3 months" in my earlier plan would give only about 45-50, which is too few. If downloads are too heavy, use the second half of 2024 and say so.
- **Drop** any listed CVE with no EPSS score at day -60 (published too recently). Count the drops and report them.

2. What counts as a twin

A twin must meet all of these:

- **Never KEV-listed** as of your data-pull date. Write that date down.
- **Published within ±30 days** of the listed CVE's publish date, so the two are the same age at day 0.
- **Same CVSS band:** Critical (9.0-10), High (7.0-8.9), Medium (4.0-6.9) or Low (below 4.0). Use NVD, and the CVE List as fallback when NVD has no score.
- **Full EPSS history** across the same -60 to +60 days.

Matching mechanics: take up to 5 twins per listed CVE, drawn at random with a fixed seed (42), and use each twin only once. If fewer than 2 twins exist, drop that listed CVE and count it. A twin is "no confirmed event," not "never attacked."

3. What day 0 is

- **Listed CVE:** day 0 is its KEV `dateAdded`.

- **Twin:** it borrows the day 0 of the listed CVE it was matched to, so both are read on the same calendar clock.
- **EPSS reading:** use the score from the daily file dated that day. If the file is missing, use the most recent earlier file, and log it.

4. The 7-day ingestion buffer

EPSS does not see a public signal the moment it appears. So:

- **First public signal** = the Exploit-DB date for that CVE, with the source recorded next to it.
- A rise that starts **before** that date counts as possible early warning.
- A rise that starts **within 7 days after** that date is treated as ingestion lag, a mechanical reaction, never as foresight.
- **Cleanest test:** CVEs with no exploit date on or before day 0. Report these separately.
- **Sensitivity check:** rerun once with a 3-day and a 14-day buffer. If your conclusion flips, say so.

5. Keep it honest

- Write down every dropped CVE and the reason.
- Do not adjust twin rules or the window after seeing the plots.
- Exploit-DB dates are the date added to the site, so they can be later than the true first release. List that as a limitation.